

Reporte Ejecutivo de Gestión de Riesgos

Dirigido al Directorio | Clínica Privada | Elaborado a partir del análisis en SimpleRisk

1. Resumen Ejecutivo

Como parte del fortalecimiento de la gestión de riesgos de la clínica, tras la reciente auditoría externa que identificó debilidades en este proceso, se realizó un relevamiento inicial utilizando la herramienta SimpleRisk. Se identificaron **7 riesgos** relevantes para la operación diaria de la institución, vinculados principalmente al manejo de las Historias Clínicas Digitales (HCD), a la gestión de dispositivos y accesos del personal, y a la dependencia de proveedores externos. De estos, **4 fueron clasificados como Alto** y **3 como Medio**, no habiéndose identificado riesgos de nivel Crítico en esta primera etapa. Ya se encuentran en marcha 3 planes de acción concretos para atender los riesgos de mayor prioridad.

2. Top 5 Riesgos por Nivel

#	Riesgo	Nivel	Impacto principal
1	Acceso indebido a HCD por curiosidad del personal	Alto (12)	Confidencialidad de datos de pacientes
2	Pérdida o robo de dispositivos móviles	Alto (12)	Exposición de HCD fuera de la clínica
3	Cuentas activas de ex-empleados	Alto (12)	Accesos no controlados al sistema
4	Dispositivos médicos conectados sin segmentar	Alto (10)	Disponibilidad de equipos críticos
5	Dependencia de proveedor único de facturación	Medio (9)	Continuidad de facturación con obras sociales

3. Estado de los Planes de Acción

Plan	Riesgo asociado	Responsable	Presupuesto	Estado
PA-01	Acceso indebido a HCD	Responsable de Seguridad	USD 1.500	Planificado
PA-02	Pérdida/robo de dispositivos	Jefe de IT	USD 1.200	Planificado
PA-03	Cuentas de ex-empleados	RRHH / Jefe de IT	USD 800	Planificado

Los tres planes se encuentran en etapa de planificación, con fechas de implementación estimadas entre 15 y 45 días. Se recomienda su aprobación formal para iniciar la ejecución.

4. Recomendaciones Prioritarias

- Aprobar y asignar presupuesto a los 3 planes de acción en curso (PA-01 a PA-03) dentro de los próximos 30 días.
- Implementar un control de acceso basado en roles (RBAC) sobre las Historias Clínicas Digitales, con registro de auditoría de accesos.
- Establecer una política formal de baja de personal (offboarding) que incluya la revocación inmediata de credenciales.

4. Evaluar la contratación de un seguro de ciberriesgos y la revisión de acuerdos de nivel de servicio (SLA) con proveedores críticos, en particular el proveedor de facturación con obras sociales.
5. Realizar un nuevo relevamiento de riesgos con una periodicidad al menos semestral, dado que el entorno de amenazas cambia constantemente.

Elaborado por: Exequiel Caliri — Responsable del análisis de riesgos | Herramienta utilizada: SimpleRisk